

STRATEGY REVIEW · 2026-10-31

Framework for regulated delivery

A review of RAVINTIO Zero against Framework's regulated strategy. It turns every useful finding into a backlog entry, ready for your review in pull request #75.

64	11	3	372
backlog entries filed	parallel review scans	urgent security gaps to fix first	bundled third-party skills to remove

DOCUMENT RFW-RPT-0001	REVISION 1.1 · 2026-10-31	STATUS Proposal for owner review
PULL REQUEST #75	BRANCH chore/0000294-zero-filed-backlog	PREPARED FOR Martin Mayer, product owner

01 The short version

Framework shouldn't chase Zero's speed. Framework wins by being the delivery pipeline that a regulated organisation can defend to an auditor.

- **Three gaps let an agent weaken its own controls today.** Fix them before anything else 0000297–0000299.
- **The bundled skill library has to go.** Its provenance data is defective. Developers bring their own approved, licensed skills through overrides instead 0000301, 0000302.
- **Four base controls carry most of the audit story.** They are attributable approvals, an audit trail, traceability, and one feature at a time. Most later entries build on them.
- **Jira becomes the system of record for planning and approval.** A named human moves each gate, and Framework binds the approval to a commit and an artefact digest 0000295, 0000352.
- **Postmortems go further than Zero's.** Zero writes good records and never closes them. Framework adds CAPA with effectiveness checks and a gate before archive 0000330–0000336.
- **Compliance frameworks become profiles.** A small set of controls is on by default. GAMP 5, ISO 27001 mapping, and UK GCAP are opt-in 0000348, 0000356.

02 Where Framework differs from Zero

Both products share an ancestor and most of their hooks. They now serve different buyers. Zero optimises for throughput across many features. Framework optimises for control, evidence, and a clear line of accountability for every change.

DIMENSION	RAVINTIO ZERO	RAVINTIO FRAMEWORK
Market	Any team that wants speed	Regulated industries: life sciences, medical devices, finance, and the public sector
Unit of work	Initiatives: many features in one unattended run	One feature at a time, behind human gates
Planning	Markdown files in the repository	Jira drives the workflow, and the repository keeps the evidence
Approvals	Chat replies that the agent writes down	A named human moves a Jira gate, bound to a commit SHA and digest
Skills	Bundled library removed in Zero 0000030	No bundled skills. Approved, licensed skills arrive through overrides
Postmortems	Blameless records that stay open	CAPA with effectiveness checks, trend analysis, and periodic review
Compliance	Not a goal	Evidence for GAMP 5, ISO 27001, NIST, OWASP, and UK GCAP through profiles

03 How the review ran

Eleven read-only scans ran in parallel, each from one angle. Their findings were checked against Framework's existing backlog to avoid duplicates. Six writers then filed the entries. Each writer checked every cited path and line against the code first, and corrected any that had moved.

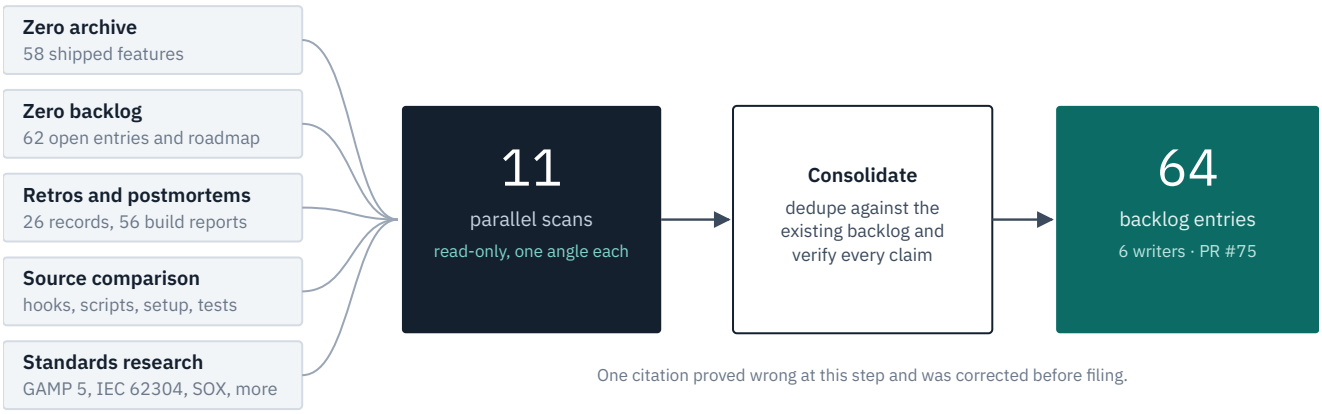


Figure 1. The review pipeline. No scan changed any file. Only the writers created files, and the orchestrator made every commit.

> **PHASE NUMBERS DIFFER BETWEEN THE TWO PRODUCTS**
>
> Zero has five phases and Framework has ten. Every entry uses Framework numbers. Where an entry cites Zero, it names the phase in full, such as Zero P2 Implement.

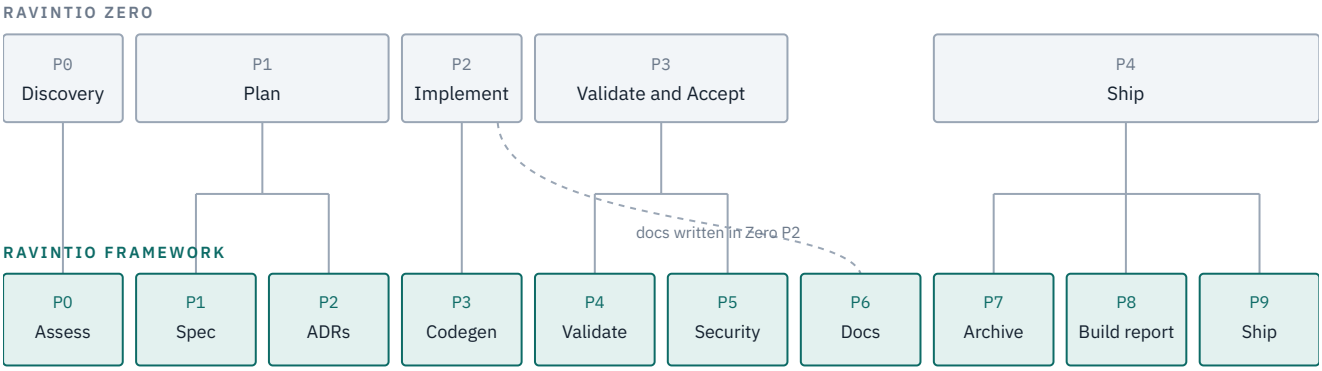


Figure 2. Phase mapping. A Zero P1 Plan finding lands in Framework P1 or P2. A Zero P3 Validate and Accept finding lands in P4 or P5.

04 Fix first: three urgent gaps

Each of these lets an agent weaken a control without a human seeing it. All three are small, self-contained Change Pipeline runs.

0000297

The write gate fails open

If `design.md` exists but has no parseable component paths list, the gate allows every write. That includes `.claude/settings.local.json`, which can switch off every hook.

`path-rules.mjs, line 897 · confirmed`

0000298

Fast Path can rewrite policy

The agent can authorise its own Fast Path writes to `ravintio-overrides/`. That folder holds the loop toggles, standing instructions, and push permission.

`workflows/fast-path.md`

0000299

Setup can leak a secret

When `settings.json` fails to parse, setup prints the parser's message. That message quotes part of the file, so a secret can reach the terminal and the agent's context.

`setup.sh and setup.ps1 · 4 sites`

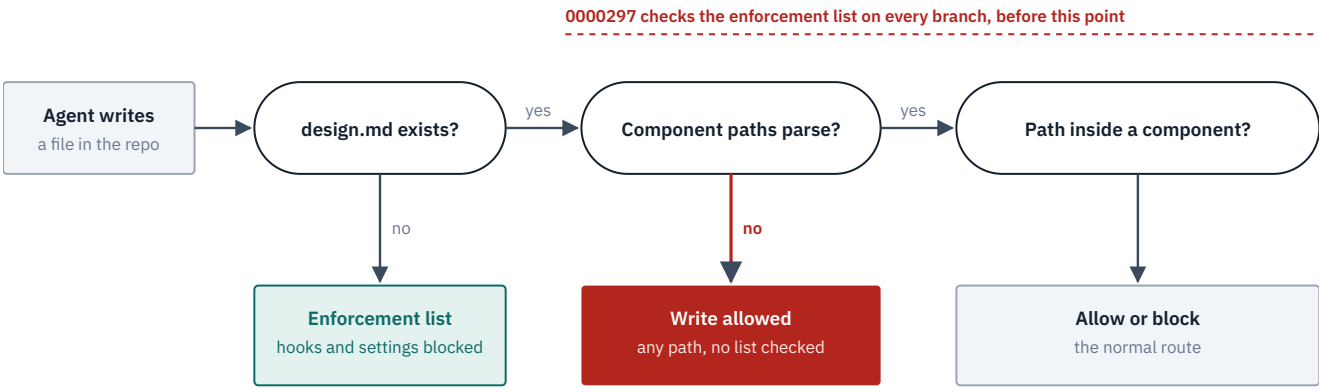


Figure 3. The gate applies its list of protected paths only when no design exists. Once any design exists, an unparseable paths section skips every check.

05 What Framework enforces, and what you choose

Framework enforces a control by default when it costs little, applies to all software, and only adds good practice. Heavy, sector-bound, or organisation-level frameworks become profiles that a team picks at P0. Some parts switch on when the design needs them.

DEFAULT On for every install. Loosening it needs a waiver.

OPTIONAL Off until a team picks the profile at P0.

TRIGGERED On when the design meets a condition.

OUT OF SCOPE Framework doesn't support it.

FRAMEWORK	PART	ENFORCEMENT	REASON
OWASP	Top 10 and ASVS Level 1	DEFAULT	Applies to all software at low cost. P1 adds criteria and P5 checks them.
	ASVS Level 2 and 3	OPTIONAL	Depth follows the risk class.
	Top 10 for LLM Applications	TRIGGERED	When the product embeds an LLM.
	MASVS	TRIGGERED	When the product is a mobile app.
	SAMM	OUT OF SCOPE	It measures an organisation's maturity.
NIST	SSDF (SP 800-218) core practices	DEFAULT	The base pipeline already evidences most of them.
	SLSA level and secure software attestation	OPTIONAL	Mainly US federal buyers need these.
	SP 800-218A	TRIGGERED	When the product embeds generative AI.
	SP 800-53, SP 800-171, and FedRAMP	OPTIONAL	Sector-bound and heavy.
	CSF 2.0	OUT OF SCOPE	Organisation-level.
ISO 27001	Data sent to the model provider 0000357	DEFAULT	Every customer's auditor asks this first.
	Annex A mapping profile	OPTIONAL	The standard certifies an organisation, not software.
GAMP 5	Attributable approvals, audit trail, and traceability	DEFAULT	These base controls help every regulated buyer.
	GxP profile: categories, specification hierarchy, validation plan, and summary report	OPTIONAL	Only GxP systems need this.
UK GCAP	UK public sector profile: Software Security Code of Practice, Secure by Design, and Cyber Assessment Framework	OPTIONAL	The code is voluntary. Binding duties come through a bill that hadn't passed by January 2026.

YOUR DECISION

This table is a proposal in entry 0000356. Confirm or change each row before 0000348 builds the profile mechanism.

06 Skills: remove, then govern

The bundled library holds 372 third-party skills. Removing it ends the redistribution duty for future releases, and past tags keep their attribution files. The provenance data shows why a regulated buyer couldn't accept the library as it stands.

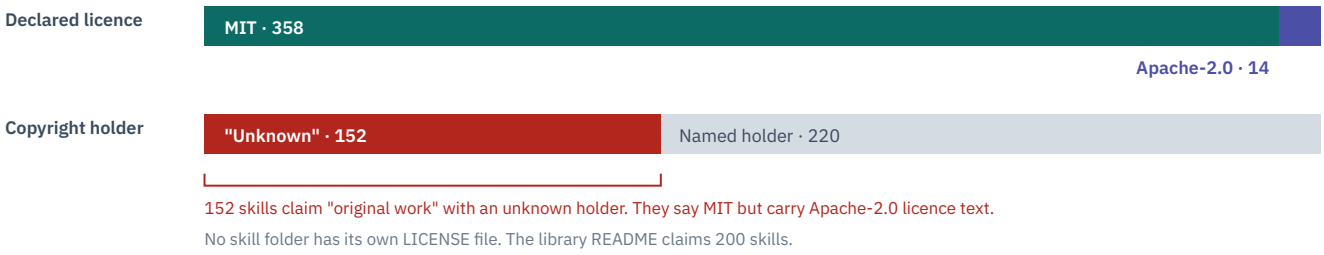


Figure 4. Licence and provenance of the bundled skills, from each folder's `attribution.txt`. Scale: full width is 372 skills.

The governed route for a team's own skills

After removal, `ravintio-overrides/capability-skills/` is the only way in. Setup installs a skill only when every check passes. Agents can draft a provenance record but can never fill in the approver.

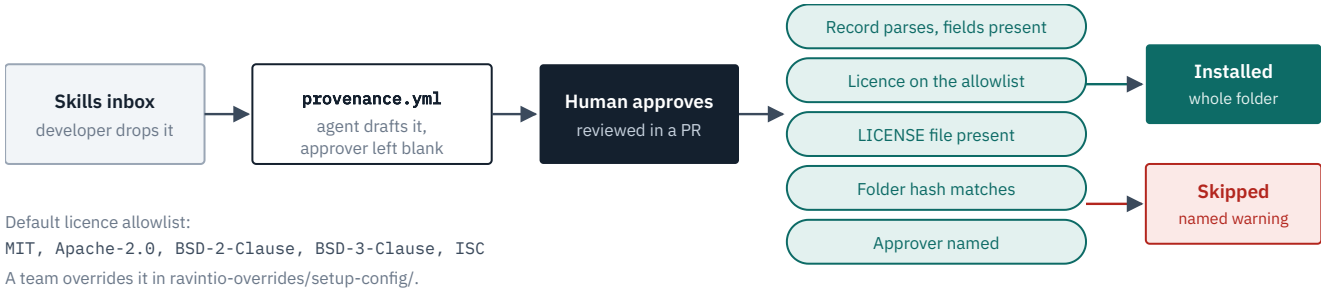


Figure 5. Bring-your-own skills under entry 0000302. Setup also copies each skill's whole folder, which fixes a defect where it copied only `SKILL.md`.

> **PREREQUISITE**
>
> Fix backlog 0000272 before 0000301. Otherwise the migration's setup re-run deletes developers' own skill folders.

07 One feature at a time, driven by Jira

One Jira Story maps to one feature, one run, one pull request, and one release. The agent moves work statuses. Only a named human can move a review status, and Jira's workflow enforces that through an approvers group that leaves out the agent's account.

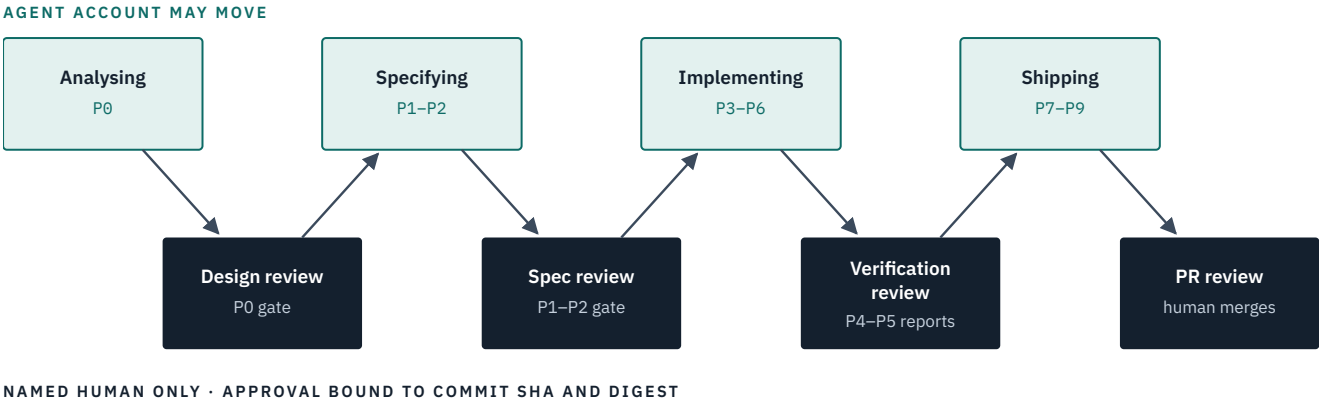


Figure 6. Proposed Jira workflow for entries 0000295 and 0000352. Each human gate records the approver's account, the time, the commit SHA, and a digest of the approved artefacts.

What makes an approval stand up

- The agent signs in to Atlassian as its own account, never the human's.
- Jira's changelog holds the identity, and nobody can edit it.
- A later gate re-hashes the artefacts. A changed file needs a fresh approval.
- Schema and destructive approvals stay in the repository.

How one feature at a time holds

- Before it claims a Story, the agent searches for any other active Story on its account and stops if it finds one.
- The repository lock carries the Jira key, and the hooks check it `0000305`.
- If Jira can't be reached, no gate can pass. Unknown never counts as approved.

08 Postmortems that go further

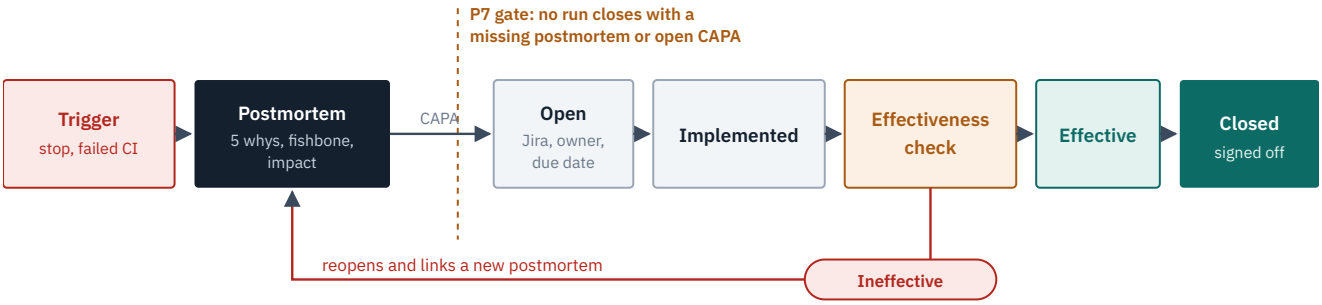
Zero's postmortems are good records. They build an evidence timeline, ask five whys, and end at a process gap rather than a person. Three things stop them working as a quality system.

WHAT ZERO'S RECORDS SHOW

All 26 postmortems and retrospectives still read `status: "open"`. Two stops got no postmortem until two days later. One lesson recurred in nine retrospectives and nothing noticed the pattern.

WHAT FRAMEWORK ADDS

Deterministic triggers and a gate before archive. Every action gets a Jira issue, a named owner, and a committed due date. An overdue action blocks the next release. Closure needs evidence that the action worked.

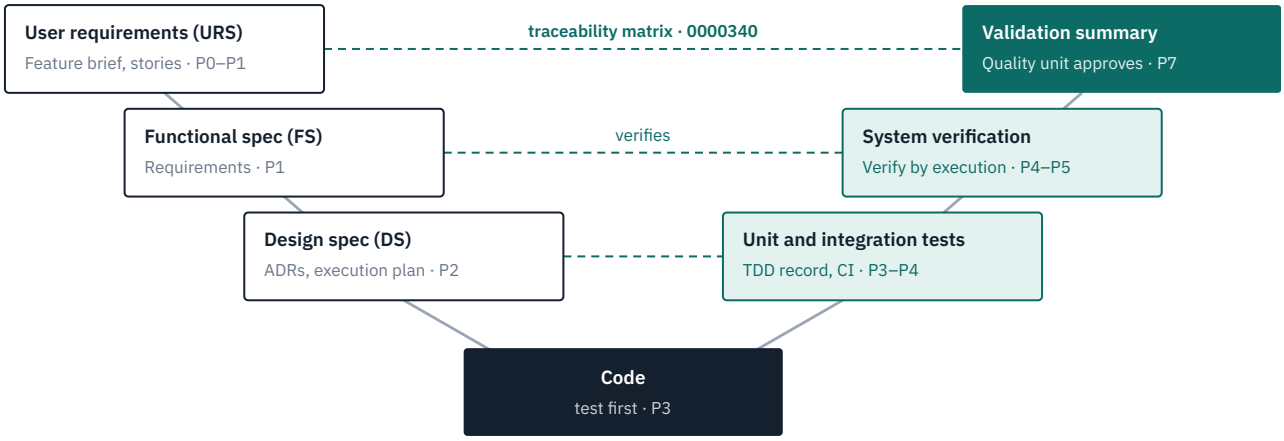


Each CAPA states a measurable criterion, for example "no recurrence in five runs" or "the detective test fails on a seeded fault".

Figure 7. CAPA lifecycle in entries 0000330 to 0000332. Framework records the evidence and links the organisation's own QMS CAPA, which stays the system of record.

09 GAMP 5 and the V-model

Framework already does much of what GAMP 5 asks. It has traceable requirements, maker-checker splits, test-first code, and verification by execution. What it lacks is the GxP vocabulary and the records that tie those steps into a validation story. The GxP profile maps Framework's artefacts onto the specification hierarchy.



Category 4 systems add a configuration specification. Risk class (0000339) sets test depth and whether a human must run or review each test.

Figure 8. GAMP 5 specification and verification levels, mapped to Framework artefacts and phases in entries 0000337 to 0000342.

Smallest defensible set

Attributable approvals `0000286`, the GxP profile `0000337`, risk-based test depth `0000339`, the traceability matrix `0000340`, and the validation summary report `0000342`.

The AI pipeline is itself a tool to qualify

Auditors ask first for an intended-use statement for the agent. Entry 0000344 pins the model ID and Framework version per artefact, and packages the test suite as qualification evidence.

> **SOURCE CHECK**
>
> The GAMP 5 Appendix D9 and D11 and ISPE AI Guide references come from general knowledge. Each entry says to check them against the source text at pickup.

10 Suggested delivery order

Framework builds one feature at a time, so the order matters. Each wave depends on the one before it. The base controls in wave 3 carry most of what later waves need.

WAVE 1

Retire Fast Path and close the three urgent gaps

Route every change through a pipeline. Stop an agent switching off its own controls or leaking a secret.

`0000358` `0000297` `0000298` `0000299`

WAVE 2

Remove the bundled skills

Fix the manifest first, then remove the library and open the governed route.

`0000272` `0000301` `0000302`

WAVE 3

Build the base controls

Protected policy, attributable approvals, a tamper-evident audit trail, git guards, and the one-feature lock.

`0000288` `0000286` `0000289` `0000303` `0000305`

WAVE 4

Put Jira at the centre

Permanent ADR homes, then Jira planning and approval records bound to commits.

`0000296` `0000295` `0000352`

WAVE 5

Add profiles and GAMP 5

Confirm the enforcement table, build the profile mechanism, then the GxP records in order.

`0000356` `0000348` `0000337` `0000339` `0000338` `0000340` `0000341` `0000342`

WAVE 6

Close the quality loop

Postmortems, CAPA, and the gate before archive, then the incident hotfix path. The remaining entries follow.

`0000330` `0000331` `0000332` `0000359`

11 Decisions for you

- [ ] **Confirm the enforcement table.**
  Accept or change each row in entry 0000356.

- [ ] **Choose where the base controls apply.**
  Decide whether they are on for every install, or only when a team picks a regulated profile.

- [ ] **Settle the initiative entries.**
  Close 0000244 and 0000245, or move them to Zero. Both port the initiative pattern.

- [ ] **Keep postmortems in Framework.**
  Revise 0000279 section 2, which moves them to RAVINTIO Insight.

- [ ] **Merge PR #74 before PR #75.**
  The new entries cite 0000280 to 0000293, which exist only on PR #74.

A Entry index

Every entry filed in PR #75, grouped by theme. Entry 0000355 also lists amendments to 20 existing entries.

ID	TITLE	ROUTE
COPIED FROM ZERO		
0000294	Put a 24-hour time before each phase prefix	To triage
0000295	Drive Framework from Jira through the Atlassian MCP	Feature
0000296	Keep ADRs in docs/adr with repo-wide numbers	Feature
URGENT CONTROLS		
0000297	Gate-write fails open when design.md has no component paths	Change
0000298	Put ravintio-overrides/ on the enforcement list	Change
0000299	Setup echoes settings content on a JSON parse error	Change
SKILLS		
0000301	Remove the bundled third-party skills	Change
0000302	Governed bring-your-own skills	Feature
CONTROLS, SETUP, AND TESTS		
0000300	Setup hook merge drops or duplicates user hooks	Change
0000303	Guard git bypasses and agent merges	Change
0000304	Git hygiene for parallel subagents	Change
0000305	One active feature per repository	Feature
0000306	Limit run modes under a regulated profile	Feature
0000307	Tighten the Change Pipeline under a regulated profile	Feature
0000308	Grant the Fast Path CI exemption by content, not commit subject	Change
0000309	Prove hook coverage at P0 with a canary write	Change
0000310	Make the test runner and assert helpers able to fail	Change
0000311	Set read-only token permissions in the consumer CI template	Change
0000312	Check build log integrity with a script	Change
0000313	Run resume detection as a script	Feature
0000314	Setup refuses uncommitted pack or override files	Change
0000315	Record failing tests on the base commit at P0	Change
0000316	Run the P4 suite in a clean clone of HEAD	Change
0000317	Installation check as qualification evidence	Feature
0000318	Override-first standards and templates	Feature
0000319	Joining a Framework repo, and turning strict mode off	Change
0000320	Agent identity and repository security settings	Change
0000321	Keep the developer's CLAUDE.md on first install	Change

ID	TITLE	ROUTE
0000322	Tag the release on main after merge	Change
0000323	Evidence before claims	Change
0000324	Test impact scan in the execution plan	Change
0000325	Explicit agreement and numbered permissions	Change
0000326	Report context size at each gate	Change
0000327	Critic flags guard widening and missing containment	Change
0000328	Writing standard and prose checks at filing	Feature
0000329	Setup target safety for agents	Change
POSTMORTEM AND CAPA		
0000330	A regulated postmortem with an impact assessment	Feature
0000331	A CAPA register with effectiveness checks	Feature
0000332	A postmortem and CAPA gate before archive	Feature
0000333	Deviation records linked to waivers and change control	Feature
0000334	Incident and problem management intake	Feature
0000335	Trend analysis across quality records	Feature
0000336	A periodic quality review and a retirement plan	Feature
GAMP 5		
0000337	GxP profile and system categorisation at P0	Feature
0000338	GAMP specification hierarchy and a living system spec	Feature
0000339	GxP quality risk assessment and risk-based test depth	Change
0000340	Requirements traceability matrix	Change
0000341	Objective test evidence standard	Change
0000342	Validation plan and summary report	Feature
0000343	Part 11, Annex 11, and ALCOA+ requirement kit	Feature
0000344	Qualify the AI pipeline as a development tool	Feature
0000345	Supplier assessment for the LLM provider and agent tool	Change
0000346	Change impact on validated state	Change
0000347	Appendix D11 trigger for AI in the built product	Change
COMPLIANCE PROFILES AND OTHER FRAMEWORKS		
0000348	Pluggable compliance profiles	Feature
0000349	SOUP and third-party component register	Feature
0000350	Safety risk controls traced to requirements and tests	Feature
0000351	Record model identity and AI contribution	Change
0000356	Decide which compliance frameworks Framework enforces by default	Feature
0000357	Control what data the agent sends to the model provider	Feature

ID	TITLE	ROUTE
JIRA		
0000352	Jira approval records bound to commit and digest	Feature
0000353	Change record gate before ship	Feature
0000354	CAPA and defect source links in templates	Change
STRATEGY RECORD AND FOLLOW-UPS		
0000355	Regulated strategy and amendments from the Zero review	Record
0000358	Retire Fast Path	Feature
0000359	Design a controlled hotfix path for incidents	Feature

B Other frameworks to assess

Entry 0000356 lists these for the same default, optional, triggered, or out-of-scope call.
The Cyber Resilience Act and IEC 81001-5-1 matter most for Framework's target market.

EU and UK regulation

Cyber Resilience Act, NIS2, DORA, the EU AI Act with ISO/IEC 42001, GDPR Article 25, and Cyber Essentials.

Life sciences and devices

IEC 62304, ISO 13485, ISO 14971, IEC 81001-5-1, FDA section 524B premarket cybersecurity, and the EU GMP Annex 11 revision and draft Annex 22.

Finance and payments

SOX IT general controls, PCI DSS v4.0 requirement 6, and SOC 2.

Industrial and automotive

IEC 62443-4-1, ISO/SAE 21434, and UNECE R155. Automotive safety standards need a tool qualification level that an LLM can't reach.

US government

CMMC 2.0, CISA Secure by Design, and the secure software self-attestation form.

Supply chain

SBOM formats (SPDX and CycloneDX), OpenSSF Scorecard, OpenChain (ISO/IEC 5230 and 18974), and CIS Controls control 16.

Sources for the UK GCAP position

Government Cyber Action Plan, GOV.UK: gov.uk/government/publications/government-cyber-action-plan

Cyber security and the UK government, House of Lords Library: lordslibrary.parliament.uk/cyber-security-and-the-uk-government

The Cyber Security and Resilience Bill explained, TLT: tlt.com/insights-and-events

Check the plan and the Bill text at pickup. This review didn't read either directly.